

1. Objetivos

Este trabalho pretende familiarizar os alunos com alguns dos problemas relacionados com a configuração de uma máquina segura, em particular com a utilização e configuração de *firewalls* e Sistemas de Detecção de Intrusões (ou *Intrusion Detection Systems* - IDS).

O trabalho consiste na configuração de uma máquina segura, utilizando as ferramentas *iptables* e *snort*, onde terá de ser executado o servidor **SpertaServer** desenvolvido no Projeto 1.

2. Organização do trabalho

Este trabalho está dividido em duas partes:

- Parte I: *iptables* – pretende-se que os alunos se familiarizem com a ferramenta *iptables* e que a utilizem de modo a configurarem a máquina segura.
- Parte II: *snort* – de forma idêntica, pretende-se que os alunos se familiarizem com a ferramenta *snort* e que a utilizem de modo a configurarem a máquina segura.

3. Ambiente de Execução

Para a realização do trabalho, os alunos irão utilizar uma máquina virtual disponibilizada no Moodle (ficheiro “mininetx-GUI-VM Seg.ova”). Esta possui a ferramenta Mininet-GUI já instalada, que permite criar e simular diversas topologias de rede. É esperado que os alunos consigam executar o servidor **SpertaServer** e o cliente **SpertaClient** (desenvolvidos no Projeto 1) neste ambiente, nomeadamente usando a topologia SegC já disponível no Mininet-GUI. Esta topologia, visível na Figura 1, simula a rede de uma casa inteligente num condomínio.

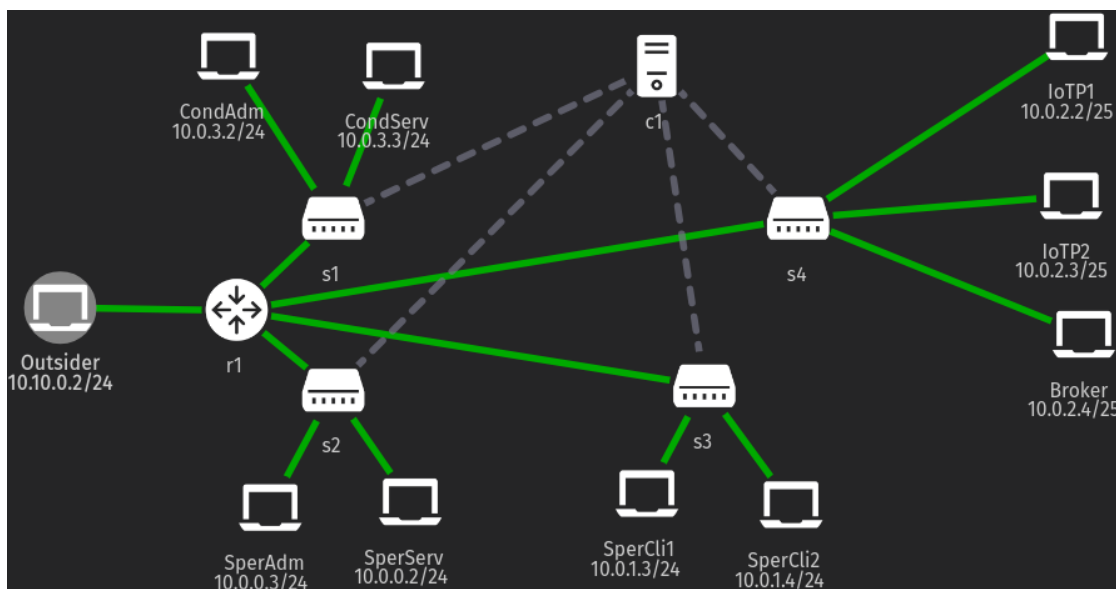


Fig.1 - Topologia SegC da ferramenta Mininet-GUI executada dentro da máquina virtual.

As instruções para a execução da máquina virtual, do cliente **SpertaClient** e do servidor **SpertaServer** na máquina virtual, e para a utilização das ferramentas **iptables** e **snort** nesse contexto, são fornecidas num ficheiro adicional disponibilizado no Moodle ("mininetx-GUI-VM Seg.ova").

4. Parte I: *iptables*

4.1. Preparação prévia

Antes da realização do projeto, os alunos deverão estudar a ferramenta **iptables** e efetuar os exercícios do guião da aula TP.

4.2. Trabalho a realizar pelo grupo

Pretende-se que os alunos utilizem o comando **iptables** para configurar a máquina **SperServ** (ver Fig. 1) de forma segura, máquina onde será executado o servidor **SpertaServer** que foi desenvolvido no Projeto 1.

A melhor maneira de garantir a segurança da máquina é reduzir os serviços que ela disponibiliza ao mínimo indispensável e garantir a sua constante atualização. Neste contexto, a *firewall* deve ser configurada de modo a concretizar a seguinte política:

- Serviços suportados (aos quais a máquina segura responde, observando as restrições descritas a seguir): **ping**, **ssh** e os serviços necessários para aceder ao servidor **SpertaServer**.
- Restrições: a máquina segura onde corre o servidor **SpertaServer** :
 - (i) responde a *pings* apenas com origem nas máquinas **SperAdm**, **CondAdm** e nas máquinas da sub-rede em que se encontram as máquinas **SperCli1** e **SperCli2** (onde correrão a aplicação **SpertaClient**);
 - (ii) aceita ligações de clientes **SpertaClient** para o servidor **SpertaServer** apenas a partir de máquinas da sub-rede em que se encontram as máquinas **SperCli1** e **SperCli2** (considerando a máscara 255.255.255.0);
 - (iii) aceita ligações *ssh* apenas da máquina **Broker** e das máquinas da sub-rede em que se encontra o próprio **SperServ** (considerando a máscara 255.255.255.0).
- Serviços utilizados: a máquina segura onde corre o servidor **SpertaServer** apenas pode realizar:
 - (i) *ping* às máquinas da sua sub-rede local (considerando a máscara 255.255.255.0) e à máquina **Broker**. Contudo, a frequência dos *pings* deve ser limitada a um máximo de 4 *pings*/segundo;
 - (ii) conexão de *ssh* à máquina **CondServ**.

Os alunos devem elaborar um relatório ([iptables.pdf](#)) com o seguinte conteúdo:

- Regras do comando **iptables** que permitem concretizar a política acima especificada. Os alunos também devem deixar explícito no relatório qual a *default policy* que adotaram, justificando-a;
- Explicação do método de teste utilizado e observações realizadas, apresentando imagens que comprovem o funcionamento das regras definidas.

Observações:

- i) o normal funcionamento dos computadores na rede dos laboratórios depende do seu acesso às seguintes máquinas:

DCs: 10.121.53.17, 10.121.53.18, 10.101.53.19

Storage: 10.121.72.33

Falua: 10.101.85.138

Luna: 10.101.85.24

Gateway: 10.0.101.9

Proxy: 10.101.85.137

Deste modo, **caso venham a testar alguma regra nos computadores do laboratório (ou seja, fora do ambiente Mininet-GUI)**, não devem impedir o acesso da máquina do laboratório a estas máquinas.

- ii) a opção `-F` do **iptables** não altera a política definida por omissão (i.e., a *default policy*). Assim, a seguinte sequência de comandos bloqueará o computador caso estejam a testar alguma regra nos computadores do laboratório, fora do ambiente Mininet-GUI (ver justificação na observação anterior):

```
$ ...  
$ sudo /sbin/iptables -P OUTPUT DROP  
$ sudo /sbin/iptables -F OUTPUT
```

- iii) O tráfego do dispositivo de *loopback* (i.e., o *localhost*; 127.0.0.1) não deve ser filtrado pelas regras definidas para a máquina segura onde corre o servidor **SpertaServer**:

```
$ sudo /sbin/iptables -A INPUT -i lo -j ACCEPT  
$ sudo /sbin/iptables -A OUTPUT -o lo -j ACCEPT
```

- iv) O tráfego relacionado com uma ligação já estabelecida com a máquina segura onde corre o servidor **SpertaServer** também deve ser aceite:

```
$ sudo /sbin/iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT  
$ sudo /sbin/iptables -A OUTPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
```

5. Parte II: *snort*

5.1. Preparação prévia

Antes da realização da Parte II do projeto, os alunos deverão estudar a ferramenta **snort** e efetuar os exercícios do guião da aula TP.

5.2. Trabalho de grupo

Pretende-se que os alunos utilizem o **snort** de modo a detetar alguns ataques contra o servidor **SpertaServer**. Os alunos devem definir uma ou mais regras **snort** para as situações descritas de seguida, potencialmente indicativas de um ataque:

- Deve ser gerado um alerta para a consola quando forem recebidas na máquina servidora 20 ou mais ligações TCP provenientes da mesma máquina para portos inferiores a 1024,

no intervalo de um minuto. Isto pode indicar um varrimento de portos. (NOTA: nesse minuto deve ser gerado **apenas** um alarme, qualquer que seja a máquina que inicia as ligações). Para testar a regra, os alunos poderão utilizar o comando `nmap` para efetuar varrimentos de portos:

```
nmap <IP alvo>
```

- Deve ser gerado um alerta para a consola sempre que forem recebidas 3 ligações da mesma máquina emissora para o porto do servidor **SpertaServer**, num intervalo de 20 segundos. Este cenário pode ser indicativo que estão a tentar descobrir uma password de acesso ao serviço. (NOTA: deve haver um alerta **por cada** conjunto de 3 ligações observadas).
- Deve ser gerado um alerta para a consola sempre que forem recebidas tentativas de ligação ao servidor **SpertaServer** a partir de máquinas que estejam fora da sub-rede em que se encontram as máquinas **SperCli1** e **SperCli2** (considerando a máscara 255.255.255.0).
- Deve ser gerado um alerta quando a máquina servidora receber mais do que 4 pings por segundo, o que pode ser o início de uma tentativa de ataque DDoS por inundação de ICMP (i.e., os pedidos de ping não têm de ter origem na mesma máquina). Deve ser gerado apenas um alarme por segundo.

Os alunos devem elaborar um relatório ([snort.pdf](#)) com o seguinte conteúdo:

- regra(s) definida(s) para o comando *snort* com o comportamento acima descrito;
- forma de invocação do comando *snort*
- método de teste utilizado e observações realizadas, apresentando imagens que comprovem o funcionamento das regras definidas.

6. Entrega

Dia **29 de maio**, até as 23:59 horas. O relatório do trabalho deve ser entregue da seguinte forma:

- Criar um **ficheiro zip** com o nome **SegC-grupoXX-proj2.zip**, onde XX é o número do grupo, contendo o relatório do *iptables* e do *snort* (2 ficheiros pdf). **Cada relatório deve ter no máximo 3 páginas.**
- Submeter o ficheiro zip através da atividade disponibilizada para esse efeito na página da disciplina no Moodle. Apenas um dos elementos do grupo deve submetê-lo. Se existirem várias submissões do mesmo grupo, será considerada a mais recente.
- Preencher, **até as 23h59 do dia 30 de maio**, o formulário sobre as contribuições do trabalho 2, o qual será disponibilizado no Moodle. **Os alunos que não preencherem o formulário sofrerão uma penalização de 10% na classificação do projeto.**

Não serão aceites trabalhos por email, nem por qualquer outro meio não definido nesta secção. Se não se verificar algum destes requisitos, o trabalho é considerado não entregue.